

Cybersecurity 101

A Process Guide for the Cyber Workforce — from first principles to the Risk Management Framework.

Purpose & Audience

This guide is the narrative companion to the Cybersecurity 101 Desk Reference and the Cybersecurity 101 presentation. It is written for anyone new to the cyber portfolio — ISSO trainees, engineers, program staff, and leaders — who needs a clear, vendor-neutral grounding in what cybersecurity is, why it works the way it does, and how those fundamentals feed directly into the Risk Management Framework (RMF) that governs authorization. No prior experience is assumed. Read it once end to end, then keep the one-page Desk Reference at your workstation.

1 · Why Cybersecurity Exists

Every mission today depends on information and the systems that store, move, and process it. That dependence is also an exposure: criminal groups, nation-state actors, and even trusted insiders attempt to steal, alter, or deny that information. Cybersecurity is the discipline of protecting information and systems so the mission can continue even in a contested environment.

A common misconception is that the goal is perfect prevention — an impenetrable wall. It is not. A sufficiently determined adversary will eventually find a way through some layer, and building for perfection is both impossible and ruinously expensive. The real goal is to manage risk to a level leadership is willing to accept, and to be able to detect, contain, and recover quickly when something does get through.

The core equation

Risk = Likelihood × Impact. We reduce risk by lowering the likelihood of a harmful event, reducing the impact if it occurs, or both. Security controls are simply the tools we use to move those two dials.

2 · The CIA Triad — The Goal of All Security

Three properties define what we are trying to protect. Nearly every control, policy, and design decision maps back to at least one of them.

Confidentiality

Information is disclosed only to those authorized to see it. It is protected by access control, encryption, and the discipline of need-to-know. A data breach is fundamentally a loss of confidentiality.

Integrity

Information and systems remain accurate and unaltered except by authorized action. It is protected by hashing, digital signatures, change control, and logging. Silent, unauthorized modification of data is a loss of integrity — often more damaging than a leak because it erodes trust in everything.

Availability

Systems and data are usable when the mission needs them. It is protected by redundancy, backups, resilience engineering, and defenses against denial-of-service. Ransomware is, at its heart, an attack on availability.

Use it as a lens

When you evaluate any control, ask which leg of the triad it protects. If you cannot answer, question whether the control is worth its cost.

3 · The Vocabulary of Risk

Clear terms prevent muddled decisions. Five words carry most of the weight:

- **Asset** — something of value you must protect: data, a system, a service, or a capability.
- **Threat** — a potential cause of harm. It may be an actor (an attacker, a careless insider) or an event (a flood, a power loss).
- **Vulnerability** — a weakness a threat can exploit: an unpatched application, a weak password, an exposed port, an untrained user.
- **Risk** — the combination of how likely it is that a threat exploits a vulnerability and how much harm results if it does.
- **Control (safeguard)** — any measure — technical, operational, or managerial — that reduces risk.

These interlock: a threat with no matching vulnerability, or a vulnerability no threat can reach, represents little risk. This is why prioritization matters — you invest first where a real threat meets a real weakness over a valuable asset.

4 · Principles That Guide Every Decision

A handful of durable principles resolve most day-to-day security judgment calls without needing a policy lookup:

- **Defense in depth** — layer independent controls so that no single failure is catastrophic. If one layer is bypassed, another still stands.
- **Least privilege** — grant the minimum access required to perform a role, and no more. Excess access is standing risk.
- **Need to know** — access should follow a legitimate, current mission need, not convenience or seniority.
- **Separation of duties** — split critical actions across people so no single individual can act unchecked.
- **Fail secure** — when a component fails, it should default to the safe, denied state rather than an open one.
- **Assume breach** — design as though an adversary will get in, emphasizing detection, containment, and recovery alongside prevention.

5 · Identity: Authentication, Authorization, Accounting

Most security ultimately rests on knowing who is acting and controlling what they may do. Three related ideas — often called AAA — capture it:

- **Authentication** — proving you are who you claim to be, using factors: something you know (a password), something you have (a token or phone), or something you are (a biometric). Multi-factor authentication (MFA) combines two or more and is the single highest-value everyday control.

- **Authorization** — determining what an authenticated user is permitted to do. This is where least privilege is enforced.
- **Accounting (audit)** — recording what was done, by whom, and when, so that actions are traceable and reviewable.

A frequent mistake

Authentication is not authorization. Successfully logging in only proves identity — it does not, by itself, mean the user should be allowed to do what they attempt next.

6 · Threats You Will Actually Meet

Headlines feature exotic zero-days, but the overwhelming majority of real incidents come from a short, familiar list:

- **Phishing and social engineering** — manipulating people rather than machines into giving up access or information. The defense is a skeptical culture: verify before you trust, and report suspicious messages.
- **Malware, including ransomware** — malicious code that steals, encrypts, or destroys. Defenses are prompt patching, restricting what can execute, and keeping tested, offline backups.
- **Credential theft and reuse** — stolen or guessed passwords. MFA and unique passphrases defeat most of it.
- **Insider threat** — misuse by trusted users, malicious or accidental. Least privilege, monitoring, and separation of duties contain it.
- **Misconfiguration and unpatched systems** — the most common real-world entry point of all, and the most preventable.

7 · From Fundamentals to the RMF

The Risk Management Framework (NIST SP 800-37) is how organizations turn the vague question "is this system secure?" into a repeatable, documented, risk-based decision. Everything above feeds it: the CIA triad drives categorization, the vocabulary of risk frames every judgment, and the principles shape which controls are selected and how. The lifecycle has seven steps:

- **0 · Prepare** — establish organizational context, roles, and a risk strategy before any system work begins.
- **1 · Categorize** — determine the system's impact level using FIPS 199 (Low/Moderate/High for confidentiality, integrity, and availability).
- **2 · Select** — choose and tailor the SP 800-53 control baseline that matches the categorization.
- **3 · Implement** — put the selected controls in place and document precisely how each is satisfied.
- **4 · Assess** — have an independent assessor test whether the controls actually work as described.
- **5 · Authorize** — the Authorizing Official weighs the residual risk and, if acceptable, issues the Authorization to Operate (ATO).
- **6 · Monitor** — sustain the authorization through continuous monitoring; significant changes feed back into the cycle.

The through-line

RMF does not replace the fundamentals — it operationalizes them. A strong implementation statement in Step 3 is just the CIA triad, least privilege, and defense in depth, written down and evidenced. For the full RMF walkthrough, see the RMF Operations Hub.

8 · Roles and Everyday Habits

Security is a team sport with clearly separated, accountable roles: the **Authorizing Official (AO)** accepts risk and signs the ATO; the **ISSM** runs the security program across systems; the **ISSO** owns day-to-day security for a specific system and its authorization package; the **Security Control Assessor (SCA)** independently evaluates controls; and the **System and Data Owners** own the mission and its risk.

Whatever your role, most real-world protection comes from disciplined basics done consistently:

- Use MFA everywhere and strong, unique passphrases — never shared.
- Lock your screen when you step away; ensure data is encrypted at rest and in transit.
- Patch promptly and report anything suspicious immediately — speed limits damage.
- Handle CUI according to its markings, and know your incident-reporting path before you need it.
- When in doubt, ask the ISSO before acting. A question is far cheaper than an incident.

Where To Go Next

- Keep the **Cybersecurity 101 Desk Reference** at your workstation for quick lookups.
- Use the **Cybersecurity 101 presentation** for briefings and onboarding sessions.
- Begin **BC-101 — Introduction to Cybersecurity & Resilience Frameworks** in the CSO Cyber Range to go deeper.
- Move on to the **RMF Operations Hub** to see how these fundamentals drive authorization in practice.

CCoE Cybersecurity Office · Cybersecurity 101 Process Guide · Version 1.0 · Effective 2026-07-08 · Review 2027-01-08.
Demonstration reference material — contains no CUI or classified information.